Xác thực giao dịch trên kênh ERP luồng web/app

Version	Date	By	Changes
1.0	26/08/2025	Thanhth2	

XÁC THỰC GIAO DỊCH GIAO DỊCH TRÊN KÊNH ERP LUỒNG WEB/ APP
1. MÔ TẢ VÀ NGUYÊN TẮC CHUNG
2. DANH SÁCH API SỬ DỤNG
2.1 API KHỞI TẠO PHIÊN XÁC THỰC GIAO DỊCH
2.2 API VẤN TIN TRẠNG THÁI PHIÊN XÁC THỰC GIAO DỊCH
2.3 API XÁC THỰC GIAO DỊCH
3. USE CASE/ LUỒNG GIAO DỊCH
3.1. XÁC THỰC GIAO DỊCH BẰNG SMART OTP
3.2. XÁC THỰC GIAO DỊCH BẰNG CHỮ KÝ SỐ TỪ XA (REMOTE SIGNING)
3.3. XÁC THỰC GIAO DỊCH BẰNG CHỮ KÝ SỐ TẠI HỆ THỐNG NỘI BỘ (QUA USB TOKEN/ HSM)
4. KÝ XÁC THỰC BẰNG USB TOKEN/ HSM

XÁC THỰC GIAO DỊCH GIAO DỊCH TRÊN KÊNH ERP LUỒNG WEB/ APP

1. MÔ TẢ VÀ NGUYÊN TẮC CHUNG

- Tài liệu này hướng dẫn cách thức và nguyên tắc xác thực 2 yếu tố đối với giao dịch phát sinh trên kênh ERP luồng Web/ App của BIDV Direct phục vụ cho việc tích hợp hệ thống giữa hệ thống khách hàng và BIDV
- Vai trò: Đảm bảo tính an toàn bảo mật khi thực hiện các giao dịch có phát sinh thay đổi tài chính của khách hàng (giao dịch tài chính)
- Các nguyên tắc chung áp dụng:
  - Tất cả các dịch vụ tài chính yêu cầu xác thực 2 yếu tố tại các bước Đẩy duyệt và Phê duyệt giao dịch (hoặc đẩy hạch toán/ xử lý với giao dịch không cần bước phê duyệt)
  - Phương thức xác thực áp dụng: Smart OTP do BIDV cung cấp hoặc Chữ ký số
  - Loại chữ ký số áp dụng: Ký số từ xa (Remote signing) hoặc Ký số tại hệ thống khách hàng (qua USB Token hoặc HSM)
- Lưu ý khác: Đối với trường hợp ký Chữ ký số tại hệ khách hàng, hệ thống khách hàng cần phải hỗ trợ chức năng cho người dùng có thể ký số bằng chữ ký số công cộng lên một mã dữ liệu cần ký số (dataSign) đã được hash do BIDV cung cấp (có thể sử dụng USB Token, HSM hoặc một phương thức khác phù hợp - nếu có)

2. DANH SÁCH API SỬ DỤNG

2.1 API KHỞI TẠO PHIÊN XÁC THỰC GIAO DỊCH

- Vai trò của API: Khởi tạo phiên xác thực tương ứng với hành động thực hiện của người dùng (đẩy duyệt/ phê duyệt...) và thông tin loại xác thực cần thực hiện với người dùng tương ứng.
- Phân loại API: Bắt buộc tích hợp để có thể hoàn thành luồng xác thực giao dịch
- Các lưu ý: API khởi tạo phiên xác thực giao dịch được tích hợp sẵn theo từng API đẩy duyệt/ phê duyệt giao dịch của từng dịch vụ. Dữ liệu input/ output mô tả dưới đây phục vụ tham chiếu đối với nội dung xác thực giao dịch. Chi tiết các trường thông tin vui lòng tham khảo đặc tả kỹ thuật của API dịch vụ tương ứng.
- Endpoint: Theo API đẩy duyệt/ phê duyệt dịch vụ tương ứng.

Ví dụ: /payment/transfer/init/1.0

Input

TT	Trường thông tin	Mô tả trường thông tin	Ghi chú/ Lưu ý
0	*(chỉ cần nêu các trường thông tin chính yếu)*	*Bắt buộc/ Không bắt buộc* *Định dạng text/ number/ time* *Mô tả*	*Giới hạn các giá trị có thể nhập* *Nguồn giá trị thông tin*

Output

TT	Trường thông tin	Mô tả trường thông tin	Ghi chú/ Lưu ý
1	transKey	Mã phiên xử lý giao dịch	Lưu ý mã phiên xử lý này chỉ có hiệu lực đến khi hoàn thành giao dịch xác thực. Cần phân biệt với Mã phiên xác thực (authID) và Số tham chiếu giao dịch (txnID)
2	RequireAuth	true/ false Giao dịch cần xác thực hay không	Mặc định "true" đối với giao dịch cần xác thực
3	authType	Loại xác thực cần thực hiện đối với người dùng	1 trong 3 giá trị tùy theo thông tin PTXT đã đăng ký của người dùng: • SMARTOTP • REMOTE • CA
4	expTime	Thời gian hiệu lực tối đa của phiên xác thực (giây)	Mặc định với Smart OTP/ CA là 120s; REMOTE là 300s
5	qrData	Nội dung cần hiển thị dưới dạng QR code theo chuẩn của VietQR	
6	authID	Mã phiên xác thực	
7	dataSign	Mã dữ liệu cần thực hiện ký số (đã được hash)	
8	serialNumer	Số serial chữ ký số của người dùng	Chỉ khả dụng với trường hợp xác thực bằng chữ ký số từ xa
9	provider	Nhà cung cấp chữ ký số của người dùng	Chỉ khả dụng với trường hợp xác thực bằng chữ ký số từ xa
10	additionalInfo	Thông tin bổ sung liên quan đến giao dịch gốc cần xác thực	

Ví dụ:

Với Phương thức xác thực là chữ ký số Usb Token/ HSM ("authType": "CA")


```
"data": {
        "transKey": "TXNKEY_INIT_PM02_8thanh_dd724ca9-8b78-4d9d-86be-f588a076af9f",
        "requireAuth": true,
        "transAuth": {
            "authType": "CA",
            "expTime": 120,
            "isSameDevice": null,
            "qrData": "OTkwMDVCMDUwMDMyMTc1NTgzNzk1MDI2Mi01YzM3MzNmYS04NzZmLTQyZjAtYWFlMC1jYjI4NDM2NTZiN2MwNjAwMDQzMjcxMjAwMDEzQklEVklCQU5LX1RSQU5TX09UUA==",
            "authId": "1755837950262-5c3733fa-876f-42f0-aae0-cb2843656b7c",
            "dataSign": "Ja2a3UIuRejARoSKLxjNFKM1Q9j6i8qbjQRTwGzdj9w=",
            "additionalInfo": {},
            "serialNumber": null,
            "provider": null
        }
    }
```


Với Phương thức xác thực là chữ ký số Remote Signing ("authType": "REMOTE")


```
"data": {
        "transKey": "TXNKEY_INIT_PM02_8remote_d87f7bf8-b8cf-4f0f-bee3-d1350a35a4aa",
        "requireAuth": true,
        "transAuth": {
            "authType": "REMOTE",
            "expTime": 300,
            "isSameDevice": null,
            "qrData": "OTkwMDVCMDUwMDMyMTc1NTkyMzc4MzMxMy0yNzlmM2I2Yi01NzFjLTQzNGItODQ2MC00NDNjYTYwMDc0YTQwNjAwMDQ2MDIxMjAwMDEzQklEVklCQU5LX1RSQU5TX09UUA==",
            "authId": "1755923783313-279f3b6b-571c-434b-8460-443ca60074a4",
            "dataSign": "/4f9aRtdRtofmle1zvMpgH3ia0bJtxjE+BXrbp74jYo=",
            "additionalInfo": {},
            "serialNumber": "54010101558db1023517ee08ecb1bdac",
            "provider": "VNPT"
        }
    }
```


Với Phương thức xác thực là SmartOTP ("authType": "SMARTOTP")


```
"data": {
        "transKey": "TXNKEY_INIT_PM02_8thanh_1331f4f3-bff8-4a23-9129-a275d7ee2f5c",
        "requireAuth": true,
        "transAuth": {
            "authType": "SMARTOTP",
            "expTime": 120,
            "isSameDevice": "N",
            "qrData": "OTkwMDVCMDUwMDMyMTc1NTkyMjE4MjA0Ni05MDRkY2M1ZC02YzQxLTRlMTktOGIxMS01MmNiNDdmMzkwYTAwNjAwMDQzMjcxMjAwMDEzQklEVklCQU5LX1RSQU5TX09UUA==",
            "authId": "1755922182046-904dcc5d-6c41-4e19-8b11-52cb47f390a0",
            "dataSign": "TkXBe8CqsFKTyfJwFZQkxenn7CAZcajj8S3ZX7G0/pE=",
            "additionalInfo": {},
            "serialNumber": null,
            "provider": null
        }
```

```
    }
```

2.2 API VẤN TIN TRẠNG THÁI PHIÊN XÁC THỰC GIAO DỊCH

- Vai trò: Vấn tin trạng thái phiên xác thực và lấy giá trị xác thực mà người dùng đã thực hiện
- Phân loại: Tùy thuộc vào PTXT áp dụng mà có cần thiết phải tích hợp API, cụ thể: Đối với phương thức xác thực Smart OTP, có thể không cần tích hợp API này và xử lý theo phần Lưu ý của User case xác thực giao dịch bằng Smart OTP phía dưới. Đối với PTXT Chữ ký số từ xa (Remote Signing) cần bắt buộc tích hợp. Đối với PTXT Chữ ký số tại hệ thống nội bộ (HSM/ USB Token) không cần tích hợp API này.
- Endpoint: /utilities/auth/trans/retrieve-status/1.0

Input

TT	Trường thông tin	Mô tả trường thông tin	Ghi chú/ Lưu ý
1	authId	Bắt buộc, Định dạng: String Mã phiên xác thực	Value của authID được lấy từ trường thông tin authID tại response của API khởi tạo phiên xác thực trước đó

Output

TT	Trường thông tin	Mô tả trường thông tin	Ghi chú/ Lưu ý
1	authValue	Giá trị xác thực	Tùy thuộc vào phương thức xác thực mà giá trị xác thực trả ra sẽ khác nhau
2	status	Trạng thái xác thực	• “PENDING”: Đang chờ xác thực • “SIGNED”: Đã ký (đối với trường hợp xác thực bằng Remote Signing • null: Trường hợp xác thực bằng SmartOTP

Ví dụ:

Với trường hợp đã xác thực bằng SmartOTP

```
"data":
{
        "authValue": "565574",
        "status": null
}
```

Với trường hợp đã xác thực bằng Remote Signing

```
"data":
{
        "authValue": "ZqE0aR69IswwTrJz+/KdB0inUTNw84GJ+UoMjhPxOQI=",
        "status": "SIGNED"
}
```

2.3 API XÁC THỰC GIAO DỊCH

- Vai trò: Xác thực và kết thúc phiên xác thực giao dịch gắn với hành động của người dùng (đẩy duyệt/ phê duyệt giao dịch
- Phân loại API: Bắt buộc tích hợp để có thể hoàn thành luồng xác thực giao dịch
- Lưu ý: API khởi tạo phiên xác thực giao dịch được tích hợp sẵn theo từng API đẩy duyệt/ phê duyệt giao dịch của từng dịch vụ. Dữ liệu input/ output mô tả dưới đây phục vụ tham chiếu đối với nội dung xác thực giao dịch. Chi tiết các trường thông tin vui lòng tham khảo đặc tả kỹ thuật của API dịch vụ tương ứng.
- Endpoint: Theo API xác thực đẩy duyệt/ phê duyệt của từng dịch vụ tương ứng.
- Ví dụ: /payment/transfer/init/confirm/1.0

Input

TT	Trường thông tin	Mô tả trường thông tin	Ghi chú/ Lưu ý
1	transKey	Mã phiên xử lý giao dịch	
2	confirmValue	Giá trị xác thực	• Trường hợp xác thực bằng Smart OTP hoặc Remote Signing thì Giá trị này lấy từ API Vấn tin trạng thái phiên xác thực ở trên • Trường hợp xác thực bằng Chữ ký số tại hệ thống khách hàng (HSM/ USB Token) giá trị này hệ thống khách hàng tự sinh theo hướng dẫn ở dưới

Ví dụ:

Xác thực bằng Smart OTP

```
{
  "transKey": "TXNKEY_INIT_PM02_100662maker_a67f3cee-ff2d-4d35-9d9a-ae90304f7d4d",
  "confirmValue": "565574"
}
```

Xác thực bằng RemoteSigning

```
{
  "transKey": "TXNKEY_INIT_PM02_100662maker_a67f3cee-ff2d-4d35-9d9a-ae90304f7d4d",
  "confirmValue": "ZqE0aR69IswwTrJz+/KdB0inUTNw84GJ+UoMjhPxOQI="
}
```

Xác thực bằng Chữ ký số tại hệ thống nội bộ (HSM/ USB Token)

```
{
  "transKey": "TXNKEY_INIT_PM02_100662maker_a67f3cee-ff2d-4d35-9d9a-ae90304f7d4d",
  "confirmValue": "eyJzaWduYXR1cmVzIjpbeyJoYXNoRGF0YSI6IlRrWEJlOENxc0ZLVHlmSndGWlFreGVubjdDQVpjYWpqOFMzWlg3RzAvcEU9Iiwic2lnbmVkVmFsdWUiOiJKV2YxVHJHbXRXZ3BLcXZxc3BjRDBsTG5HdjF2a0tIRWZxS3FnZmV6UkE2QUtnOEdCZXZlQWxRdG0xY1AxRm5xR20wVFVYZHRkUndFSzFpLzNvV2c0cHRvRmhKSFRPeDEyUmZBRzdDKzFiWmNoOUtFSExrMmVhRUZISU50T2E4V2R0SFZuWFBoZEI5VUM0ZlloNFB3c3JnNTZQbE9xQmc1VTVobURKK2Z1VE09In1dLC
```

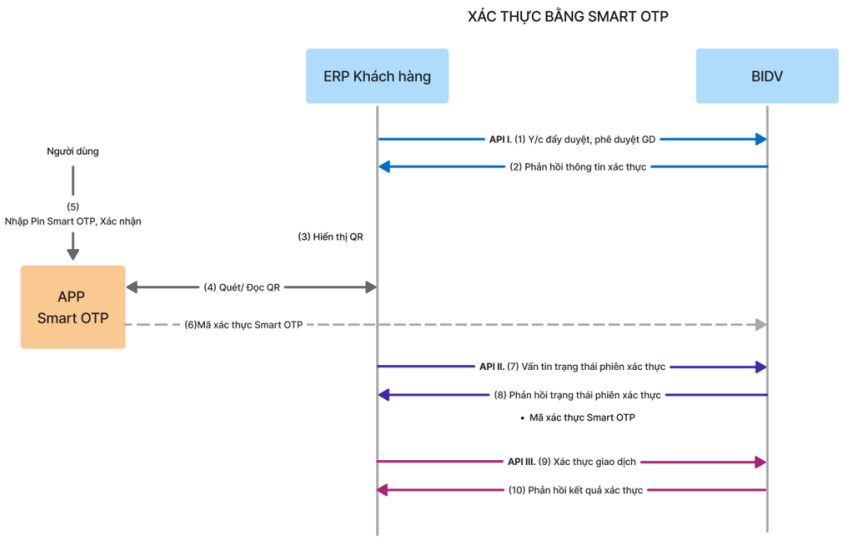
```
JjZXJ0IjoiTUlJRVdqQ0NBMEtnQXdJQkFnSVFWQVQvL3JjRFA3TWt0eWpUd3R5SDFqQU5CZ
2txaGtpRzl3MEJBUXNGQURBL01SZ3dGZ11EV1FRRERBOVdhV1YwZEdWc0xVTkJJRk5JUVRJ
eEZqQVVCZ05WQkFvTURWWnBaWFIwWld3Z1IzSnZkWEF4Q3pBSkJnTlZCQVlUQWxaT01CNFh
EVEkxTURZd01qQTRNemd3TUZvWERUSTFNVEl3TWpBNE16Z3dNRm93Z1pneEN6QUpCZ05WQk
FZVEFsWk9NUkl3RUFZRFZRUUhEQWxJdzRBZ1R1RzdtRWt4VlRCVEJnTlZCQU1NVEVQRGxFN
UhJRlJaSUVQaHU1UWdVRWpodXFaT0lNU1E0YnFtVlNCVXhxOGdXTU9DV1NCRTRidXdUa2Nn
VnNPQUlGUkl4cS9Hb0U1SElFM2h1cUJKSUV0SlRTQlFTTU9hSUUxSlRrZ3hIakFjQmdvSmt
pYUprL0lzWkFFQkRBNU5VMVE2TURFd056azFOekkzTVRDQm56QU5CZ2txaGtpRzl3MEJBUU
VGQUFPQmpRQXdnWWtDZ11FQXNZWEJKWUJ0UDM2alUxWWxRYlBNZUNubGZSNnJqVlNTb0tSQ
XppNUJaS3VDeWpiSXVEL3E2emFLNG16akFVUmdqMVIyRUdGV29JenR1ZTZXL0JmeHB6UEpx
enNncHBmZEZ0V2xqWCtmaGpYbytQaXZnaDVqVkZJM0FTa0JBRXhSYm5SdmMvU2NxcVl5NHo
vRENtNXVEQlRvcmhyekJHRlc3U2NZYnR5eEJjRUNBd0VBQWFPQ0FYb3dnZ0YyTUF3R0ExVW
RFd0VCL3dRQ01BQXdId11lEVlIwakJCZ3dGb0FVUTlVMUFJdStCN3JqVGVZZUpGbFdpRnUre
kVvd2VnWUlLd11CQlFVSEFRRUViakJzTUVNR0NDc0dBUVVGQnpBQ2hqZG9kSFJ3Y3pvdkwz
WnBaWFIwWld3dFkyRXVkbTR2Wkc5M2JteHZZV1J6TDNOMVlpOVdhV1YwZEdWc0xVTkJYMU5
JUVRJdVkzSjBNQ1VHQ0NzR0FRVUZCekFCaGhsb2RIUndPaTh2YjJOemNDNTJhV1YwZEdWc0
xXTmhMblp1TUJNR0ExVWRKUVFNTUFvR0NDc0dBUVVGQndNRU1JR0VCZ05WSFI4RWZUQjdNS
G1nTXFBd2hpNW9kSFJ3T2k4dlkzSnNMblpwWlhSMFpXd3RZMkV1ZG00dlZtbGxkSFJsYkMx
RFFTMVRTRUV5TFRJdVkzSnNva09rUVRBL01SZ3dGZ11EV1FRRERBOVdhV1YwZEdWc0xVTkJ
JRk5JUVRJeEZqQVVCZ05WQkFvTURWWnBaWFIwWld3Z1IzSnZkWEF4Q3pBSkJnTlZCQVlUQW
xaT01CMEdBMVVkRGdRV0JCUnRRZjAycnM4WGxod2thS2szdDRBUTA0MFBGakFPQmdOVkhRO
EJBZjhFQkFNQ0JlQXdEUVlKS29aSWh2Y05BUUVMQlFBRGdnRUJBSEV0UUF6VWVwUnFKK2hp
WkdwSGowVWkrQk1OOW50OUpxdWRFOHJHakl4OXVhNXdycGRHYkRuazRjMDBMYjA4MXJPWEl
2dUxUQVRQTHU2MFBaZFFiNTNzWkN2ZFlucGNjWUpjVVdJRThqczF5ek1RTHZpVE4vbjZKam
1PQnIwS1d5Sk1PNTdYQ1c5QlZXSzBlcFVDbFZEQ29PS1ozVnViL0xVcVdFaDVxTzVydHFOe
GQ2cjZnZTlvY0tlVXRDL2hzR1puOUtKbGNnVnNTMzd5M1RXUkQ4cVJvanhsemlycEZibFFz
ejNhTDV0a1JFRThXZDcySFEzQ0dNUTgyOGMvcVdFOWlKS1A4d3pLMU1MSVNRQXpHUzBicFJ
kZlRlakd0MmVzSXVtK1ZZQkErSThYVWUxZDhrcURxOXE2cTZFWTlFY0lVUllpbW1oMWRWWU
thdmZCR2lJPSJ9"
}
```


Output

TT	Trường thông tin	Mô tả trường thông tin	Ghi chú/ Lưu ý
0	*def (chỉ cần nêu các trường thông tin chính yếu đáp ứng nhu cầu và mô tả luồng nghiệp vụ)*	*Định dạng text/ number/ time* *Description*	*Các giá trị có thể có* *Mục đích, vai trò của giá trị*

3. USE CASE/ LUỒNG GIAO DỊCH

3.1. XÁC THỰC GIAO DỊCH BẰNG SMART OTP



Bước 1: Hệ thống khách hàng gọi API đẩy duyệt/ phê duyệt giao dịch tới BIDV

Lưu ý: chi tiết API theo mô tả của từng loại dịch vụ cụ thể, ví dụ:

- Đối với dịch vụ chuyển tiền trong nước:
  - API Lưu, lưu-đẩy duyệt giao dịch chuyển tiền đơn: /payment/transfer/init/1.0
  - API Đẩy duyệt giao dịch đã lưu: /payment/transfer/process-transaction/1.0
  - API phê duyệt giao dịch chuyển tiền: /payment/transfer/approve/1.0

Bước 2: BIDV phản hồi thông tin xác thực liên quan đến giao dịch, cụ thể:

+ Mã phiên xác thực

+ Phương thức xác thực áp dụng (trường hợp này là Smart OTP)

+ Thời gian hiệu lực tối đa của phiên xác thực

+ QRData: Nội dung cần hiển thị dưới dạng QR code theo chuẩn của VietQR

+ Các thông tin về giao dịch gốc cần xác thực

Bước 3: Hệ thống khách hàng chuyển đổi thông tin QRData thành mã QR và hiển thị lên giao diện cho người sử dụng thấy (có thể hiển thị kèm các thông tin giao dịch gốc để người dùng nhận diện)

Bước 4: Người dùng mở app BIDVDirect trên thiết bị di động đã kích hoạt Smart OTP, quét mã QR hiển thị trên giao diện của hệ thống khách hàng

Bước 5: Người dùng khách hàng nhập mã PIN Smart OTP, xác nhận giao dịch xác thực

Bước 6: Trường hợp người dùng nhập đúng mã PIN và ấn xác nhận, App BIDVDirect thực hiện gửi mã xác thực về BIDV

Bước 7: Hệ thống khách hàng sau khi nhận phản hồi tại bước 2, ngay lập tức gọi API vấn tin trạng thái phiên xác thực tới BIDV.

- Trường hợp nhận được phản hồi phiên xác thực hợp lệ, thực hiện bước 9
- Trường hợp nhận được phản hồi phiên xác thực chưa hoàn tất, tiếp tục gọi lại API vấn tin này sau khoảng thời gian nhất định **(đề xuất sau 5s)**

- Trường hợp hết thời gian hiệu lực của phiên xác thực mà chưa nhận được phản hồi về phiên xác thực hợp lệ, kết thúc giao dịch và trả lỗi.

API sử dụng: Tham chiếu API Vấn tin trạng thái phiên xác thực

Lưu ý: Bước 7 được thực hiện liên tục song song với các Bước 4,5,6 và lặp lại đến khi nhận được phiên xác thực hợp lệ hoặc hết thời gian của phiên xác thực (*)

Bước 8: Hệ thống phản hồi trạng thái phiên xác thực về hệ thống khách hàng tương ứng. Nếu BIDV đã nhận được mã xác thực Smart OTP hợp lệ từ App BIDV Direct của người dùng thì phản hồi về hệ thống khách hàng.

Bước 9: Hệ thống khách hàng nhận được Mã xác thực Smart OTP, gọi API xác thực giao dịch tới BIDV (**)

Lưu ý: chi tiết API theo mô tả của từng loại dịch vụ cụ thể, ví dụ:

- Đối với dịch vụ chuyển tiền trong nước:
  - API Xác thực lưu-đẩy duyệt chuyển tiền đơn: /payment/transfer/init/confirm/1.0
  - API Xác thực đẩy duyệt chuyển tiền đã lưu: /payment/transfer/confirm/1.0
  - API Xác thực phê duyệt giao dịch chuyển tiền: /payment/transfer/approve-confirm/1.0

Bước 10: BIDV nhận được thông tin xác thực từ hệ thống khách hàng, kiểm tra và phản hồi kết quả về hệ thống khách hàng.

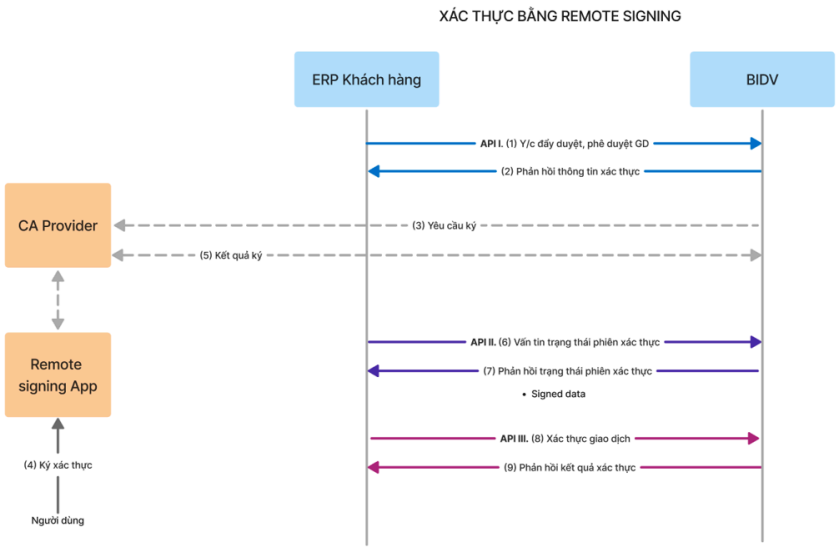
Trường hợp thông tin xác thực hợp lệ, kết thúc phiên xác thực giao dịch, chuyển xử lý giao dịch gốc tới bước tiếp theo.

Lưu ý:

(*): Trường hợp nếu khách hàng không tích hợp API vấn tin trạng thái phiên xác thực thì có thể thiết kế màn hình nhập mã OTP ở hệ thống nội bộ, khi đó người dùng cần vào app Smart OTP lấy mã và nhập tại màn hình nội bộ và ấn xác nhận. Tuy nhiên phương án này sẽ không xử lý được trường hợp người dùng ấn Xác nhận ở app Smart OTP, khi đó giao dịch ở hệ thống nội bộ khách hàng sẽ không xử lý được tiếp, bắt buộc phải thực hiện lại thao tác giao dịch trước đó (ví dụ đẩy duyệt lại giao dịch)

(**): Hệ thống khách hàng có thể thiết kế thêm màn hình để người dùng có thể nhập mã OTP hiển thị trên app Smart OTP và ấn xác nhận. Khi đó người dùng có thể ấn Xác nhận ở hệ thống ERP thay vì ấn Xác nhận ở app Smart OTP

3.2. XÁC THỰC GIAO DỊCH BẰNG CHỮ KÝ SỐ TỪ XA (REMOTE SIGNING)



Bước 1: Hệ thống khách hàng gọi API đẩy duyệt/ phê duyệt giao dịch tới BIDV.

Lưu ý: chi tiết API theo mô tả của từng loại dịch vụ cụ thể.

Bước 2: BIDV phản hồi thông tin xác thực liên quan đến giao dịch, cụ thể:

- Mã phiên xác thực
- Phương thức xác thực áp dụng (trường hợp này là chữ ký số từ xa – Remote Signing)
- Thời gian hiệu lực tối đa của phiên xác thực
- Các thông tin về giao dịch gốc cần xác thực

Bước 3: Hệ thống BIDV gửi yêu cầu ký tới CA Provider (tổ chức cung cấp dịch vụ chứng thực chữ ký số).

Bước 4: Người dùng mở ứng dụng ký số của đơn vị cung cấp chữ ký số, thực hiện ký xác thực giao dịch.

Bước 5: Hệ thống BIDV nhận kết quả ký từ CA Provider sau khi người dùng đã hoàn tất ký số xác thực giao dịch

Bước 6: Hệ thống khách hàng, ngay sau khi nhận phản hồi tại bước 2, gọi API vấn tin trạng thái phiên xác thực tới BIDV.

- Trường hợp nhận được phản hồi phiên xác thực hợp lệ, thực hiện bước 8
- Trường hợp nhận được phản hồi phiên xác thực chưa hoàn tất, tiếp tục gọi lại API vấn tin này sau khoảng thời gian nhất định (**đề xuất sau 5s**)
- Trường hợp hết thời gian hiệu lực của phiên xác thực mà chưa nhận được phản hồi về phiên xác thực hợp lệ, kết thúc giao dịch và trả lỗi.

API sử dụng: Tham chiếu API Vấn tin trạng thái phiên xác thực

Lưu ý: Bước 6 được thực hiện liên tục song song với các Bước 3, 4, 5 và lặp lại đến khi nhận được phiên xác thực hợp lệ hoặc hết thời gian của phiên xác thực.

Bước 7: Hệ thống phản hồi trạng thái phiên xác thực về hệ thống khách hàng. Nếu BIDV đã nhận được dữ liệu đã ký (signed data) hợp lệ từ CA Provider, thì phản hồi dữ liệu xác thực (confirmValue) về hệ thống khách hàng.

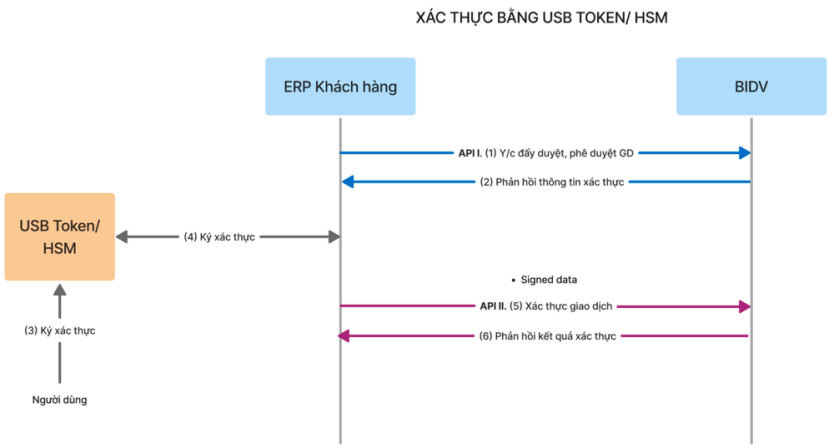
Bước 8: Hệ thống khách hàng nhận được dữ liệu xác thực (confirmValue), gọi API xác thực giao dịch tới BIDV

Lưu ý: chi tiết API theo mô tả của từng loại dịch vụ cụ thể

Bước 9: BIDV nhận được thông tin xác thực từ hệ thống khách hàng, kiểm tra và phản hồi kết quả về hệ thống khách hàng.

Trường hợp thông tin xác thực hợp lệ, kết thúc phiên xác thực giao dịch, chuyển xử lý giao dịch gốc tới bước tiếp theo.

3.3. XÁC THỰC GIAO DỊCH BẰNG CHỮ KÝ SỐ TẠI HỆ THỐNG NỘI BỘ (QUA USB TOKEN/ HSM)



Bước 1: Hệ thống khách hàng gọi API đẩy duyệt/ phê duyệt giao dịch tới BIDV.

Lưu ý: chi tiết API theo mô tả của từng loại dịch vụ cụ thể.

Bước 2: BIDV phản hồi thông tin xác thực liên quan đến giao dịch, cụ thể:

- Mã phiên xác thực
- Phương thức xác thực áp dụng (trường hợp này là USB Token)
- Đoạn data đã hash cần thực hiện ký (dataSign)
- Thời gian hiệu lực tối đa của phiên xác thực
- Các thông tin về giao dịch gốc cần xác thực

Bước 3, Bước 4: Người dùng thực hiện ký xác thực giao dịch bằng thiết bị USB Token hoặc HSM tại hệ thống nội bộ khách hàng (ký lên đoạn dataSign BIDV gửi ở Bước 2)

Bước 5: Hệ thống khách hàng gọi API xác thực giao dịch tới BIDV, gửi kèm dữ liệu đã ký (signed data).

Lưu ý: chi tiết API theo mô tả của từng loại dịch vụ cụ thể

Bước 6: BIDV nhận dữ liệu xác thực từ hệ thống khách hàng, kiểm tra và phản hồi kết quả về hệ thống khách hàng.

Trường hợp thông tin xác thực hợp lệ, kết thúc phiên xác thực giao dịch và chuyển xử lý giao dịch gốc tới bước tiếp theo.

4. KÝ XÁC THỰC BẰNG USB TOKEN/ HSM

Đối với trường hợp hệ thống khách hàng ký số bằng USB Token/ HSM để xác thực giao dịch, hệ thống khách hàng cần sinh giá trị theo hướng dẫn dưới đây:

Bước 1: BIDV gửi dữ liệu cần ký về hệ thống khách hàng (đã được hash)

```
"dataSign": "TkXBe8CqsFKTyfJwFZQkxenn7CAZcajj8S3ZX7G0/pE="
```

Trường hợp giao dịch có nhiều hash cần ký cùng lúc, dữ liệu sẽ có dạng:

```
<bổ sung>
"dataSign": "hash1;hash2;..."
```

Bước 2: Hệ thống khách hàng thực hiện ký trên đoạn dữ liệu trên và output dạng JSON trả ra như sau:


```
{"signatures":
[{"hashData":"TkXBe8CqsFKTyfJwFZQkxenn7CAZcajj8S3ZX7G0/pE=","signedValu
e":"JWf1TrGmtWgpKqvqspcD0lLnGv1vkKHEfqKqgfezRA6AKg8GBeveAlQtm1cP1FnqGm0
TUXdtdRwEK1i/3oWg4ptoFhJHTOx12RfAG7C+1bZch9KEHLk2eaEFHINtOa8WdtHVnXPhdB
9UC4fYh4Pwsrg56PlOqBg5U5hmDJ+fuTM="}],"cert":"MIIEWjCCA0KgAwIBAgIQVAT//
rcDP7MktyjTwtyH1jANBgkqhkiG9w0BAQsFADA/MRgwFgYDVQQDDA9WaWV0dGVsLUNBIFNI
QTIxFjAUBgNVBAoMDVZpZXR0ZWwgR3JvdXAxCzAJBgNVBAYTAlZOMB4XDTI1MDYwMjA4Mzg
wMFoXDTI1MTIwMjA4MzgwMFowgZgxCzAJBgNVBAYTAlZOMRIwEAYDVQQHDAlIw4AgTuG7mE
kxVTBTBgNVBAMMTEPDlE5HIFRZIEPhu5QgUEjhuqZOIMSQ4bqmVSBUxq8gWMOCWSBE4buwT
kcgVsOAIFRIxq/GoE5HIE3huqBJIEtJTSBQSMOaIE1JTkgxHjAcBgoJkiaJk/IsZAEBDA5N
U1Q6MDEwNzk1NzI3MTCBnzANBgkqhkiG9w0BAQEFAAOBjQAwgYkCgYEAsYXBJYBtP36jU1Y
lQbPMeCnlfR6rjVSSoKRAzi5BZKuCyjbIuD/q6zaK4mzjAURgj1R2EGFWoIztue6W/Bfxpz
PJqzsgppfdFtWljX+fhjXo+Pivgh5jVFI3ASkBAExRbnRvc/ScqqYy4z/DCm5uDBTorhrzB
GFW7ScYbtyxBcECAwEAAaOCAXowggF2MAwGA1UdEwEB/wQCMAAwHwYDVR0jBBgwFoAUQ9U1
AIu+B7rjTeYeJFlWiFu+zEowegYIKwYBBQUHAQEEbjBsMEMGCCsGAQUFBzAChjdodHRwczo
vL3ZpZXR0ZWwtY2Eudm4vZG93bmxvYWRzL3N1Yi9WaWV0dGVsLUNBX1NIQTIuY3J0MCUGCC
sGAQUFBzABhhlodHRwOi8vb2NzcC52aWV0dGVsLWNhLnZuMBMGA1UdJQQMMAoGCCsGAQUFB
wMEMIGEBgNVHR8EfTB7MHmgMqAwhi5odHRwOi8vY3JsLnZpZXR0ZWwtY2Eudm4vVmlldHRl
bC1DQS1TSEEyLTIuY3JsokOkQTA/MRgwFgYDVQQDDA9WaWV0dGVsLUNBIFNIQTIxFjAUBgN
VBAoMDVZpZXR0ZWwgR3JvdXAxCzAJBgNVBAYTAlZOMB0GA1UdDgQWBBRtQf02rs8XlhwkaK
k3t4AQ040PFjAOBgNVHQ8BAf8EBAMCBeAwDQYJKoZIhvcNAQELBQADggEBAHEtQAzUepRqJ
+hiZGpHj0Ui+BMN9nt9JqudE8rGjIx9ua5wrpdGbDnk4c00Lb081rOXIvuLTATPLu60PZdQ
```

```
b53sZCvdYnpccYJcUWIE8js1yzMQLviTN/n6JjmOBr0KWyJMO57XCW9BVWK0epUClVDCoOK
Z3Vub/LUqWEh5qO5rtqNxd6r6ge9ocKeUtC/hsGZn9KJlcgVsS37y3TWRD8qRojxlzirpFb
lQsz3aL5tkREE8Wd72HQ3CGMQ828c/qWE9iJKP8wzK1MLISQAzGS0bpRdfTejGt2esIum+V
YBA+I8XUe1d8kqDq9q6q6EY9EcIURYimmh1dVYKavfBGiI="}
```

Trường hợp có hơn một hash được ký cùng lúc:

```
<bổ sung>
{"signatures":
[{"hashData":"hash1;hash2;...","signedValue":"value1;value2;..."}],"cer
t":"MIIEWjCCA0KgAwIBAgIQVAT..."}
```

Cơ chế ký/ mã hóa: RSA theo PKCS#1 v1.5

Trong đó:

- hashData: Input BIDV đã gửi
- signedValue: Nội dung ký
- cert: Chứng thư số dùng để ký

Bước 3: Mã hóa BASE64 output JSON ở Bước 2:

```
eyJzaWduYXR1cmVzIjpbeyJoYXNoRGF0YSI6IlRrWEJlOENxc0ZLVHlmSndGWlFreGVubjd
DQVpjYWpqOFMzWlg3RzAvcEU9Iiwic2lnbmVkVmFsdWUiOiJKV2YxVHJHbXRXZ3BLcXZxc3
BjRDBsTG5HdjF2a0tIRWZxS3FnZmV6UkE2QUtnOEdCZXZlQWxRdG0xY1AxRm5xR20wVFVYZ
HRkUndFSzFpLzNvV2c0cHRvRmhKSFRPeDEyUmZBRzdDKzFiWmNoOUtFSExrMmVhRUZISU50
T2E4V2R0SFZuWFBoZEI5VUM0ZllloNFB3c3JnNTZQbE9xQmc1VTVobURKK2Z1VE09In1dLCJ
jZXJ0IjoiTUlJRVdqQ0NBMEtnQXdJQkFnSVFWQVQvL3JjRFA3TWt0eWpUd3R5SDFqQU5CZ2
txaGtpRzl3MEJBUXNGQURBL01SZ3dGZ1lEVlFRRERBOVdhV1YwZEdWc0xVTkJJRk5JUVRJe
EZqQVVCZ05WQkFvTURWWnBaWFIwWld3Z1IzSnZkWEF4Q3pBSkJnTlZCQVlUQWxaT01CNFhE
VEkxTURZd01qQTRNemd3TUZvWERUSTFNVEl3TWpBNE16Z3dNRm93Z1pneEN6QUpCZ05WQkF
ZVEFsWk9NUkl3RUFZRFZRUUhEQWxJdzRBZ1R1RzdtRWt4VlRCVEJnTlZCQU1NVEVQRGxFNU
hJRlJaSUVQaHU1UWdVRWpodXFaT0lNU1E0YnFtVlNCVXhxOGdXTU9DV1NCRTRidXdUa2NnV
nNPQUlGUkl4cS9Hb0U1SElFM2h1cUJKSUV0SlRTQlFTTU9hSUUxSlRrZ3hIakFjQmdvSmtp
YUprL0lzWkFFQkRBNU5VMVE2TURFd056azFOekkzTVRDQm56QU5CZ2txaGtpRzl3MEJBUUV
GQUFPQmpRQXdnWWtDZ1lFQXNZWEJKWUJ0UDM2alUxWWxRY1BNZUNubGZSNnJqVlNTb0tSQX
ppNUJaS3VDeWpiSXVEL3E2emFLNG16akFVUmdqMVIyRUdGV29JenR1ZTZXL0JmeHB6UEpxe
nNncHBmZEZ0V2xqWCtmaGpYbytQaXZnaDVqVkZJM0FTa0JBRXhSYm5SdmMvU2NxcVl5NHov
RENtNXVEQlRvcmhyekJHR1c3U2NZYnR5eEJjRUNBd0VBQWFPQ0FYb3dnZ0YyTUF3R0ExVWR
Fd0VCL3dRQ01BQXdId1lEVlIwakJCZ3dGb0FVUTlVMUFJdStCN3JqVGVZZUpGbFdpRnUrek
Vvd2VnWUlLd1lCQlFVSEFRRUViakJzTUVNR0NDc0dBUVVGQnpBQ2hqZG9kSFJ3Y3pvdkwzW
nBaWFIwWld3dFkyRXVkbTR2Wkc5M2JteHZZV1J6TDNOMVlpOVdhV1YwZEdWc0xVTkJYMU5J
UVRJdVkzSjBNQ1VHQ0NzR0FRVUZCekFCaGhsb2RIUndPaTh2YjJOemNDNTJhV1YwZEdWc0x
XTmhMblp1TUJNR0ExVWRKUVFNTUFvR0NDc0dBUVVGQndNRU1JR0VCZ05WSFI4RWZUQjdNSG
1nTXFBd2hpNW9kSFJ3T2k4dlkzSnNMblpwWlhSMFpXd3RZMkV1ZG00dlZtbGxkSFJsYkMxR
FFTMVRTRUV5TFRJdVkzSnNva09rUVRBL01SZ3dGZ11EVlFRRERBOVdhV1YwZEdWc0xVTkJJ
Rk5JUVRJeEZqQVVCZ05WQkFvTURWWnBaWFIwWld3Z1IzSnZkWEF4Q3pBSkJnTlZCQVlUQWx
aT01CMEdBMVVkRGdRV0JCUnRRZjAycnM4WGxod2thS2szdDRBUTA0MFBGakFPQmdOVkhROE
JBZjhFQkFNQ0JlQXdEUVlKS29aSWh2Y05BUUVMQlFBRGdnRUJBSEV0UUF6VWVwUnFKK2hpW
kdwSGowVWkrQk1OOW50OUpxdWRFOHJHakl4OXVhNXdycGRHYkRuazRjMDBMYjA4MXJPWEl2
dUxUQVRQTHU2MFBaZFFiNTNzWkN2ZFlucGNjWUpjVVdJRThqczF5ek1RTHZpVE4vbjZKam1
PQnIwS1d5Sk1PNTdYQ1c5QlZXSzBlcFVDbFZEQ29PS1ozVnViL0xVcVdFaDVxTzVydHFOeG
Q2cjZnZTlvY0tlVXRDL2hzR1puOUtKbGNnVnNTMzd5M1RXUkQ4cVJvanhsemlycEZibFFze
jNhTDV0a1JFRThXZDcySFEzQ0dNUTgyOGMvcVdFOWlKS1A4d3pLMU1MSVNRQXpHUzBicFJk
ZlRlakd0MmVzSXVtK1ZZQkErSThYVWUxZDhrcURxOXE2cTZFWTlFY01VUllpbW1oMWRWWUt
hdmZCR2lJPSJ9
```

Bước 4: Sử dụng nội dung ở Bước 3 là giá trị confirmValue để truyền vào API xác thực giao dịch tương ứng.

Sample code (USB TOKEN VIETTEL CA - MAC OS):

```python
import PyKCS11
import base64
import json
import getpass
import pyperclip  # thư viện để copy vào clipboard
```

```
6
7  # Đường dẫn thư viện Viettel PKCS#11
8  LIB_PATH = "/usr/local/lib/viettel-ca_v6.dylib"
9
10 # DigestInfo prefix cho SHA256 (ASN.1 structure)
11 DIGEST_INFO_PREFIX_SHA256 = bytes.fromhex(
12     "3031300d060960864801650304020105000420"
13 )
14
15 def main():
16     # Nhập hashData từ người dùng (Base64 chuỗi đã SHA256)
17     hash_data_b64 = input("Nhập hashData (Base64 SHA-256): ").strip()
18
19     try:
20         hash_bytes = base64.b64decode(hash_data_b64)
21     except Exception as e:
22         print("❌ Lỗi: Không thể decode hashData (Base64)")
23         return
24
25     if len(hash_bytes) != 32:
26         print("❌ Lỗi: hashData không phải SHA-256 hợp lệ (phải dài 32
   byte)")
27         return
28
29     # Kết hợp DigestInfo prefix + hash để tạo input ký
30     digest_info = DIGEST_INFO_PREFIX_SHA256 + hash_bytes
31
32     # Load thư viện PKCS#11
33     pkcs11 = PyKCS11.PyKCS11Lib()
34     pkcs11.load(LIB_PATH)
35
36     # Mở slot đầu tiên có token
37     slots = pkcs11.getSlotList(tokenPresent=True)
38     if not slots:
39         print("❌ Không tìm thấy USB Token.")
40         return
41     slot = slots[0]
42
43     session = pkcs11.openSession(slot)
44
45     # Nhập PIN
46     pin = getpass.getpass("Nhập PIN của Token: ")
47     session.login(pin)
48
49     try:
50         # Lấy chứng thư số (certificate)
51         cert_obj = session.findObjects([(PyKCS11.CKA_CLASS,
   PyKCS11.CKO_CERTIFICATE)])[0]
52         cert_der = bytes(session.getAttributeValue(cert_obj,
   [PyKCS11.CKA_VALUE])[0])
53         cert_b64 = base64.b64encode(cert_der).decode('utf-8')
54
55         # Lấy khóa bí mật
56         priv_key_obj = session.findObjects([
57             (PyKCS11.CKA_CLASS, PyKCS11.CKO_PRIVATE_KEY)
58         ])[0]
59
60         # Ký digest_info bằng cơ chế CKM_RSA_PKCS (không hash lại)
61         mechanism = PyKCS11.Mechanism(PyKCS11.CKM_RSA_PKCS, None)
62         signed_bytes = bytes(session.sign(priv_key_obj, digest_info,
   mechanism))
63         signed_b64 = base64.b64encode(signed_bytes).decode('utf-8')
64
65         # Tạo JSON output
66         output_json = {
67             "signatures": [{
68                 "hashData": hash_data_b64,
69                 "signedValue": signed_b64
70             }],
71             "cert": cert_b64
72         }
```

```
        json_str = json.dumps(output_json, separators=(',', ':'))
        print("\n=== JSON Output ===")
        print(json_str)

        # Mã hóa toàn bộ JSON sang Base64
        json_b64 = base64.b64encode(json_str.encode('utf-8')).decode('utf-8')
        print("\n=== Base64 JSON ===")
        print(json_b64)

        pyperclip.copy(json_b64)
        print("\n[✅ Đã copy Base64 JSON vào clipboard]")

    finally:
        session.logout()
        session.closeSession()

if __name__ == "__main__":
    main()

```